Multi-tenant background agents

Julen Gamboa. Principal AI Engineer take-home. 14 Oct 2026.

Solution design

The design uses three main parts: a scheduler, a container, and the egress proxy.

1. **Scheduler.** It fits runs in a 90-minute window under tenant and host caps; the rest escalate.
2. **Container.** Each run gets its own locked-down container, described under Sandbox.
3. **Egress proxy.** Every outbound call goes through it. It maps the run token to a tenant, enforces the run's tool list, checks the budget, injects the real key and writes the journal; the agent switches model on failure. Two instances run side by side and share only Postgres.

Stack

Postgres 16 holds the step journal, outbox, memberships and eval records, with forced row-level security. Python 3.12 runs the scheduler, proxy and agent loop. Docker runs each agent container and Postgres. `make drill` starts Postgres, applies migrations and runs each failure scenario on recordings. The drill replays recorded calls, injects an error and a rate limit, marks both `simulated`, and finishes on the recorded fallback.

Scheduling 200 agents

Agents give a deadline, not a start minute, so 200 briefs due at 07:30 spread across 90 minutes instead of all firing at 06:00. Earliest deadline first is designed; the build uses `job_id` order, behind these limits:

- **Provider (designed):** requests and tokens per minute. When full, a run waits or switches model. A self-hosted model is one more provider, sized by its batch slots.
- **Tenant:** each tenant has a concurrency limit, and it says how many of its runs happen at once.
- **Host:** 8 containers, each with 0.5 CPU and 512 MB of RAM.
- **Rate limits:** runs start on the API. On a 429 the agent falls back to the next model and logs `provider_fallback`. Backoff, a per-tenant quota split and batching are designed, not built.

A run that does not fit is escalated: 200 ten-minute runs at 2 per tenant place 72 and escalate 128.

Sandbox

A container run (in the drill, kill and escape) gets a new container: a regular user on a read-only filesystem, a 64 MB scratch disk, no extra capabilities, no privilege escalation, the default seccomp profile, and process, CPU and memory limits. The proxy refuses `py.exec`; spreadsheet code is a fixed program run by the agent, cells on stdin.

The container can talk to the proxy and nothing else. Its run token names the run but is not a credential. The proxy ties the token to the container's IP, reads the tenant and allowlist from it, and adds the real provider key on the way out. Another tenant's mail returns `foreign_id` and logs `policy_denied`; `/etc/shadow` and the internet fail in the container. The `CONNECT` and loopback check is tested, not live.

Failure and resume

Each step is keyed by `run_id`, `step_no` and a hash of messages and tool arguments; the model is not in the key, so a run can switch model mid-flight. The proxy writes `STARTED` before calling out and `COMPLETED` or `FAILED` before replying. Postgres has its own container, so a killed worker leaves the journal intact. A run is `SUCCEEDED` only if its artifact cites real message IDs from its own tenant; no artifact means `FAILED`.

Every failure ends in one of three logged outcomes:

1. **Auto-resume.** A killed worker resumes in a new container with the same `run_id` and a new token generation, skipping completed steps; the drill triggers it, no lease watcher yet. A hang is retried once, then fails. Three provider errors, or one 429, switch to the next model and log `provider_fallback`. Sandbox denials are logged; three escalate.

2. **Rerun with logged cost.** Only a newer generation reruns a step that died while `STARTED`, and it logs `cost_uncertain`; the same generation gets 202.
3. **Hand to a person.** A loop (the same call 3 times) stops as `STOPPED_LOOP`; a replayed call that would pass `max_usd` is refused and the run stops as `STOPPED_BUDGET`. Both save progress first. A person also takes over after 3 resumes, when every model is down, or on a third sandbox denial.

Tenants, evals, memory, panel, drafts

Tenants. Each user has one tenant membership with a role: viewer, approver or admin. There is no signup flow; a membership is a row. Isolation has two layers, and both hold if an agent is compromised: the proxy checks the run token's tenant scope on every call and alone holds the provider key, and Postgres row-level security scopes every query to that tenant, so an unscoped query returns no rows. In the drill, the approver is a membership row.

Evals. Each agent has a baseline of 20 or more recorded cases with expected outputs, including the injection email; the synthetic mailbox (about 30 emails, four tenants) is the workload, not the baseline. A temperature-0 judge model scores each case 1 to 5. Hard checks must pass: tenant-only data, no unflagged external draft, matching spreadsheet figures. A new prompt or model gets a new config hash and reruns the same baseline, keeping scores comparable. `evals run` writes an `eval_record` only if hard checks pass and the mean drops 0.3 or less; the first record uses hard checks only.

Memory. Memory is Postgres rows keyed to a tenant and an agent: a cursor marking the last item processed and facts saved with `memory.write`. Row-level security scopes every read and write to the run token's tenant. They are not yet loaded into the prompt. The cursor moves only on `SUCCEEDED`, but `mail.list` does not read it yet.

Panel (design only). Three models answer blind, then challenge each other's claims with evidence over two rounds. The parent returns agreed claims, contested ones with how each was settled, and any minority view kept, because agreement is not proof.

Drafts. Agents write drafts but cannot send. Sending is a separate action that needs an approver in the same tenant; it sets `Message-ID` from the draft ID and moves the outbox from `SENDING` to `SENT`, and after a crash it checks by that ID, so a replay never sends twice. A draft that goes outside the tenant's domains or attaches documents is flagged; approval does not yet treat it differently. Mail enters the prompt as quoted data, not instructions, so a malicious email gets no further than a flagged draft.

Not building

Live mailbox and document connectors, a web UI, OIDC, a replica, multi-host scheduling and the panel. The synthetic service has the connector interface, so a real connector drops in. Also not built: deadline order, rate pacing, a lease watcher, and step, token and time limits.

No gVisor or Firecracker microVMs: the build has two days, and microVMs need KVM on a Linux host. The trade-off is a shared kernel: a kernel exploit in one container could escape to the host and reach other tenants. The live call that crosses `max_usd` still goes out. Most drill scenarios skip the container.

The weakest part, and how to harden it

The proxy. It holds every credential, the tenant map and the budget ledger. Two instances survive a crash, but they run the same code, so one bug breaks tenancy for every run. Hardening takes about one week. Each step starts as a failing property test:

1. **Detect leaks**: canary IDs per tenant; a fuzzer over token, tenant and path.
2. **Stop sharing the kernel**: a Firecracker microVM per run from a warm pool.
3. **No long-lived secrets**: a vault and a broker issuing five-minute, one-tenant tokens.
4. **Separate failure domains**: gateway, broker and ledger over mutual TLS, each failing closed.
5. **A journal that survives a host**: a synchronous Postgres replica and lease fences.